AegisAI — Executive Architecture Overview

Enterprise AI Security, Governance & Compliance Auditing Platform on Google Cloud

100% Serverless — Cloud Run Infrastructure
Zero Trust — Perimeter & Identity
Model Armor — Real-time AI Guardrails
ISO/IEC 42001 — Continuous Governance

End-to-End Audit Lifecycle

1. **Request Submission** — User or CI/CD initiates audit
2. **Zero-Trust Perimeter** — Identity & domain whitelist check
3. **Evidence Extraction** — Engine parses blueprints & configs
4. **Model Armor Firewall** — Input screened for prompt attacks
5. **Gemini Reasoning** — Verdicts mapped to ISO & AISVS
6. **Evidence & SOC Alert** — Report saved, events sent to SIEM

1 — Who Accessed

Users, Pipelines & Admins

Corporate Users

Enterprise team members sign in using standard corporate Google Workspace accounts. Zero software installation required.

Google Identity · Allowed Domains

CI/CD Pipelines

Automated security scans in GitHub Actions, GitLab CI, or Jenkins. Blocks deployment if AI compliance score falls below threshold.

Automated Gate · OIDC Tokens

Security Operations

Security teams and auditors manage compliance frameworks, view real-time risk alerts, and export executive audit packs.

Admin Console · Role-based

Executive Dashboard

Modern React SPA delivering interactive compliance heatmaps, gap analyses, and downloadable board-ready PDF audit reports.

Real-time UI · Live Stream

1 HTTPS Ingress

2 ID Token

2 — Perimeter & Auth

Zero Trust Identity Gate

Google Front End (GFE)

Global Anycast edge network providing DDoS mitigation, TLS 1.3 encryption, and Google-managed automated SSL certificates.

Global Edge · TLS 1.3

Identity-Aware Proxy

Verifies user identity and strict domain whitelist before requests touch application code. Complete Zero-Trust perimeter barrier.

Zero Trust Gate · No VPN needed

Firebase Auth Engine

Issues tamper-proof, short-lived JWT identity tokens for in-app authorization, strictly tied to verified Google accounts.

OAuth 2.0 / OIDC · Short-lived

Secret Manager

Centralized cryptographic key and credential vault. Zero credentials stored in code, Git repositories, or environment files.

Keyless Security · Auto-rotated

3 Auth Request

3 — AegisAI Platform

Cloud Run Serverless Compute

API Gateway & Anti-DoW

Single hardened entry point. Validates caller authorization, enforces API rate limits, and defends against Denial-of-Wallet exploitation.

Cloud Run Service · Auto-scales to zero

Audit Intelligence Engine

Parses architecture blueprints and policies. Maps technical findings directly to ISO/IEC 42001, OWASP AISVS, and EU AI Act controls.

Core Logic · Multi-framework

AI Router & Fallback Mesh

Orchestrates model requests with automated multi-provider failover, strict timeout enforcement, and token budget management.

High Availability · 99.9% Uptime

GCP Security Posture Scanner

Automated cloud discovery auditing IAM configurations, VPC settings, and AI workloads against CIS Foundations benchmarks.

Infrastructure Audit · Real-time Scan

4 Sanitize

5 AI Reasoning

4 — Google AI Engine

Vertex AI & Responsible Guardrails

Google Model Armor

Real-time bidirectional AI firewall. Neutralizes prompt injections and jailbreaks on input; filters sensitive data and toxic content on output.

Active Guardrails · Sub-15ms inline

Gemini 3.8 Flash (Vertex AI)

Google Cloud flagship multimodal AI. Performs deep analytical reasoning over technical evidence, generating defensible compliance verdicts.

Enterprise AI · Keyless ADC

Model Garden & Registry

Curated, verified model supply chain. Ensures only cryptographically signed and vetted models are invoked across the lifecycle.

Supply Chain Security · Tamper-proof

Vertex Evaluation & Monitoring

Continuous quality and drift supervision. Benchmarks model accuracy, hallucination rates, and safety drift against production SLOs.

Quality Gate · AutoSxS Rater

6 Save Verdict

5 — Audited Data Store

Firestore Multi-Region Encrypted

Audit Repository

Immutable compliance verdicts, verbatim technical evidence, and remediated architecture models.

Audits Collection

Compliance Standards

Live regulatory catalogs: ISO 42001:2023, OWASP AISVS v1.0, EU AI Act, Mexico NOM.

Standards Catalog

API Key Credential Store

Scoped, revocable programmatic credentials for CI/CD pipelines and external automation.

Key Vault

Security Event Ledger

Audit trail of injection attempts, unauthorized access trials, and anomalous evaluations.

Security Alerts

Firestore Security Rules

Multi-region nam5 database. Encrypted at rest & in transit. Client access strictly enforced at database tier.

nam5 Multi-Region · CMEK Encrypted

7 Security Log

8 SIEM Push

6 — SecOps & ISO 42001

Observability & Continuous Compliance

Cloud Logging

Immutable, centralized audit logs recording every request, evaluation step, and AI interaction.

Tamper-proof Log

Security Command Center

Enterprise threat detection with AI Protection. Automatically escalates prompt injections to SOC incidents.

Active Threat Intel

Cloud Monitoring

Real-time operational dashboards tracking latency, error budgets, and 95%+ citation grounding SLOs.

SLO Alerting

SIEM & SOC Webhooks

Instant incident forwarding to enterprise SOCs (Chronicle, Splunk, Sentinel) via authenticated webhooks.

Enterprise SIEM

ISO Phase 3: Develop

Verified supply chain via Model Garden, active prompt sanitization with Model Armor, and automated remediation plans.

AI Protections · Controls A.6-A.8

ISO Phase 4: Evaluate

Objective AutoSxS autorating and reproducible safety evaluations serving as formal quality gate before promotion.

AI Evaluation · Clause 9.1

ISO Phase 5: Deploy

Immutable container hashes, zero-downtime revision rollouts, and pre-traffic zero-trust smoke testing.

Controlled Release · Clause 10.1

Clause 10: Improvement

Audit verdicts and security findings automatically feed back into architectural redesign, closing the governance loop.

Continuous Loop · Feedback Cycle

Real-Time SSE Result Stream

Google Cloud Enterprise Defense-in-Depth Foundation

Certified FedRAMP High · HIPAA · SOC 1/2/3 · PCI-DSS Compliant Infrastructure

- **Cloud Armor** — Enterprise L7 WAF & DDoS protection
- **VPC Service Controls** — Data exfiltration prevention perimeter
- **Workload Identity** — Zero static service account keys
- **Artifact Registry** — Vulnerability scanning & provenance
- **Binary Authorization** — Cryptographic container signature validation
- **Confidential Computing** — Memory encryption in use via AMD SEV
- **nam5 Multi-Region** — High-availability geo-redundant storage
- **Customer-Managed Keys** — CMEK envelope encryption at rest

Data Flow Notation

- User / API Ingress
- Zero-Trust Identity Validation
- Security & Model Armor Guardrails
- Vertex AI Inference & Reasoning
- Encrypted Database Transaction
- Real-time Stream / SOC Incident Event

Standards Benchmark Coverage

- **ISO/IEC 42001:2023** · Certified AI Management
- **OWASP AISVS v1.0** · AI Verification Standard
- **EU AI Act Ready** · High-Risk AI Compliance
- **Mexico NOM AI Ready** · National Standard Alignment